Case 03 – Intrusion Analysis

RH

Tabular presentation of events:

Event number	Private IP address / victim side	Public IP address / attacker side	Domain	Event	Role
1	10.1.4.102	88.208.7.193	datitngforllivess.info	The user's browser first retrieves the HTML content of the page (hash.md5: *bd7e...7ebe*) and immediately afterwards an HTML file classified as malicious (hash.md5: *a341...6ab6*). After the downloads, the browser is redirected onward.	**Initial page / malvertising starting point:** The user is "lured" to this page, and the malicious HTML on the page initiates a redirect toward the exploit chain.
2	10.1.4.102	185.56.233.186	freebitc.pro	There is HTTPS traffic between the browser and the server; the content is encrypted, so the exact events cannot be seen. It is known that the connection to this address occurs after the malicious HTML has been downloaded, after which the browser is redirected to the next IP address.	**Possible intermediary server, part of the malvertising chain:** Receives traffic coming from the previous page and redirects the browser onward to the exploit kit server.
3	10.1.4.102	185.178.47.70	-	Several HTTP POST and GET requests associated with Suricata alerts: 'RIG EK URI Struct', 'SunDown EK RIP Landing', 'Outdated Flash Version', 'Suspicious Possible CollectGarbage in base64', and the suspicious UA 'xa4'. A malicious Flash file (hash.md5: *2d12...a288*) is also downloaded from this IP address, along with the malware file dropped by the exploit (hash.md5: *0dbd...4fed*).	**Exploit kit server (RIG/SunDown):** A landing page that profiles the browser, detects the outdated Flash version, and delivers a malicious SWF exploit that drops and executes malware on the victim's machine.
4	10.1.4.102	185.68.93.192	letitbit.su	First, a DNS query is made to this domain, followed by HTTP POST requests, all of which receive a 404 response. Suricata alerts include 'Sharik/Smoke CnC Beacon', as well as several 'HTTP Request to .su TLD Often Malware Related' entries. The POST requests occur approximately every 10 minutes.	**C2 server (C&C, Command and Control):** The malware installed on the user's machine (a SmokeLoader-type Trojan) connects to this server, announces its "presence" (beaconing), and periodically checks whether there are new commands or additional malware to download.

Figure 1. Tabular presentation of events in chronological order

Security Onion screenshots:

Timestamp	event.dataset	rule.name	event.severity_label	source.ip	source.port	destination.ip
2019-01-04 21:45:25.979 +02:00	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017 M2	high	10.1.4.102	49207	185.178.47.70
2019-01-04 21:45:26.153 +02:00	suricata.alert	ET EXPLOIT_KIT SunDown EK RIP Landing M1 B642	high	185.178.47.70	80	10.1.4.102
2019-01-04 21:45:26.153 +02:00	suricata.alert	ET EXPLOIT_KIT SunDown EK RIP Landing M1 B643	high	185.178.47.70	80	10.1.4.102
2019-01-04 21:45:26.331 +02:00	suricata.alert	ET EXPLOIT_KIT SunDown EK RIP Landing M4 B642	high	185.178.47.70	80	10.1.4.102
2019-01-04 21:45:26.331 +02:00	suricata.alert	ET HUNTING Suspicious Possible CollectGarbage in base64 1	low	185.178.47.70	80	10.1.4.102
2019-01-04 21:45:26.836 +02:00	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Jun 13 2017	high	10.1.4.102	49208	185.178.47.70
2019-01-04 21:45:26.836 +02:00	suricata.alert	ET INFO Outdated Flash Version M1	high	10.1.4.102	49208	185.178.47.70
2019-01-04 21:45:30.947 +02:00	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Jun 13 2017	high	10.1.4.102	49213	185.178.47.70
2019-01-04 21:45:30.947 +02:00	suricata.alert	ET USER_AGENTS Observed Suspicious UA (xa4)	medium	10.1.4.102	49213	185.178.47.70

Figure 2. IDS alerts from the Exploit Kit server

2019-01-04 21:45:26.836 +02:00	suricata.alert	ET INFO Outdated Flash Version M1	high	10.1.4.102	49208	185.178.47.70

Figure 3. Suricata detects activity related to an outdated Flash version

2019-01-04 21:45:48.816 +02:00	suricata.alert	ET DNS Query for .su TLD (Soviet Union) Often Malware Related	medium	10.1.4.102	54078	10.1.4.1	53
2019-01-04 21:45:49.409 +02:00	suricata.alert	ET MALWARE Sharik/Smoke CnC Beacon 11	high	10.1.4.102	49224	185.68.93.192	80
2019-01-04 21:45:49.409 +02:00	suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	medium	10.1.4.102	49224	185.68.93.192	80
2019-01-04 21:45:51.717 +02:00	suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	medium	10.1.4.102	49225	185.68.93.192	80
2019-01-04 21:56:08.772 +02:00	suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	medium	10.1.4.102	49227	185.68.93.192	80
2019-01-04 22:06:17.652 +02:00	suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	medium	10.1.4.102	49229	185.68.93.192	80

Figure 4. Suricata flags DNS activity due to a query to the letitbit.su domain, after which it detects Sharik/Smoke CnC Beacon activity, followed by continuous “check-ins” to the letitbit.su domain

Kibana screenshots:

Figure 5. Downloading a malicious HTML file

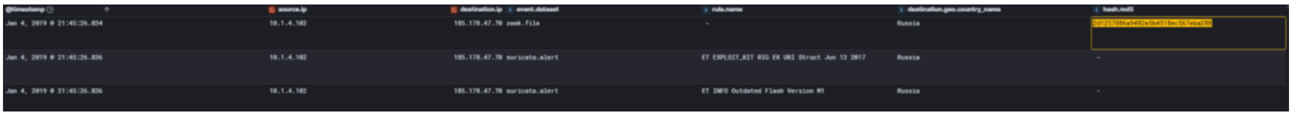


Figure 6. Downloading a Shockwave/Flash exploit that takes advantage of an outdated Flash version

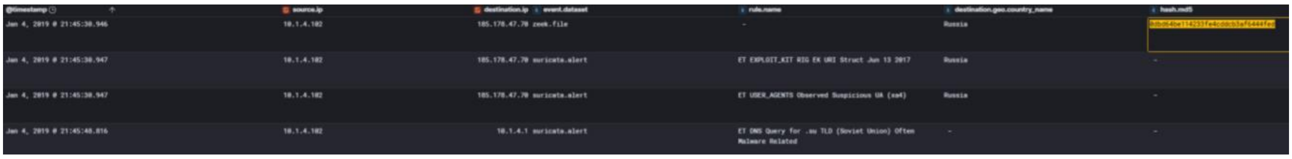
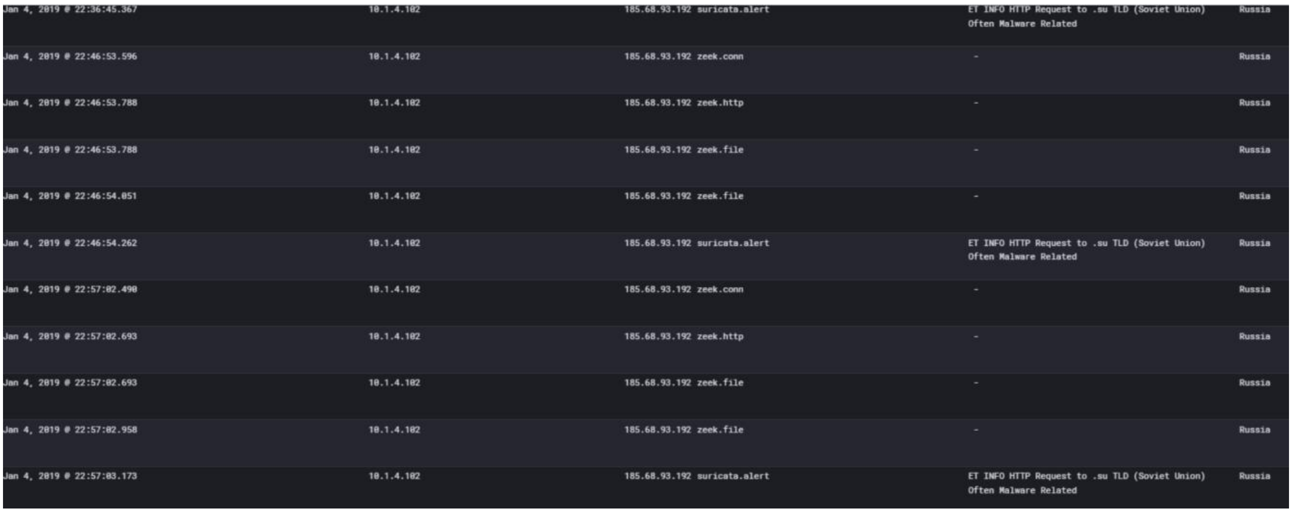


Figure 7. Downloading the malware file, after which DNS queries to a .su domain can be seen



Jan 4, 2019 @ 22:36:45.367	10.1.4.102	185.68.93.192 suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	Russia
Jan 4, 2019 @ 22:46:53.596	10.1.4.102	185.68.93.192 zeek.conn	-	Russia
Jan 4, 2019 @ 22:46:53.788	10.1.4.102	185.68.93.192 zeek.http	-	Russia
Jan 4, 2019 @ 22:46:53.788	10.1.4.102	185.68.93.192 zeek.file	-	Russia
Jan 4, 2019 @ 22:46:54.051	10.1.4.102	185.68.93.192 zeek.file	-	Russia
Jan 4, 2019 @ 22:46:54.262	10.1.4.102	185.68.93.192 suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	Russia
Jan 4, 2019 @ 22:57:02.490	10.1.4.102	185.68.93.192 zeek.conn	-	Russia
Jan 4, 2019 @ 22:57:02.693	10.1.4.102	185.68.93.192 zeek.http	-	Russia
Jan 4, 2019 @ 22:57:02.693	10.1.4.102	185.68.93.192 zeek.file	-	Russia
Jan 4, 2019 @ 22:57:02.958	10.1.4.102	185.68.93.192 zeek.file	-	Russia
Jan 4, 2019 @ 22:57:03.173	10.1.4.102	185.68.93.192 suricata.alert	ET INFO HTTP Request to .su TLD (Soviet Union) Often Malware Related	Russia

Figure 8. Sharik/Smoke CnC Beacon communication with the letitbit.su domain

Screenshots from the VirusTotal service (malware identification):

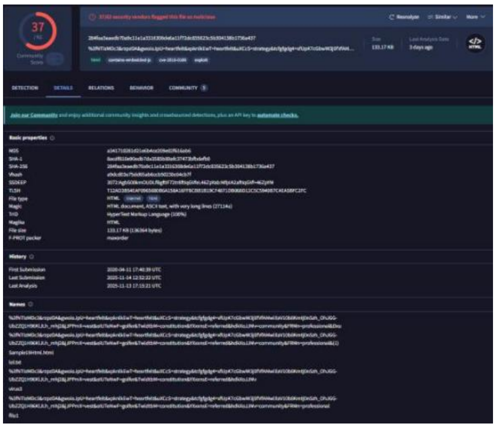


Figure 9. Malicious HTML file, possibly a page related to exploit kits

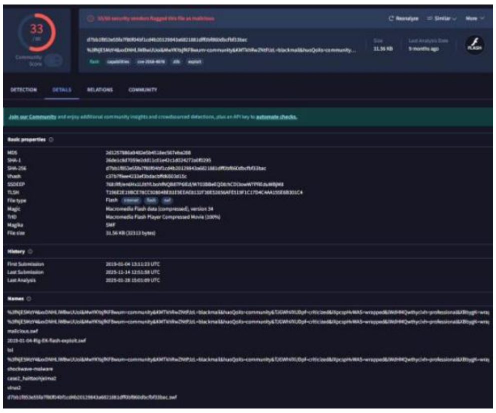


Figure 10. Malicious SWF file exploiting an outdated Flash version

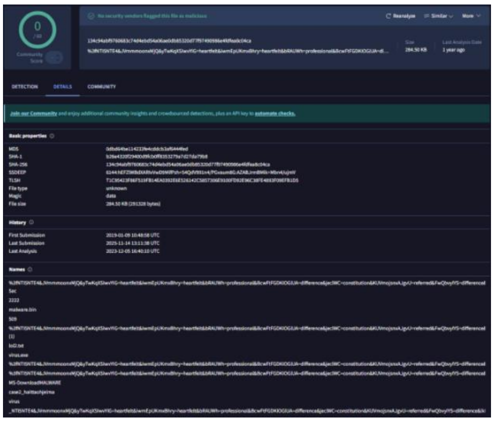


Figure 11. The actual malware, possibly a SmokeLoader-type Trojan

How I used AI (ChatGPT) in the assignment:

- Answering the initial background-knowledge questions
- Security Onion Import Node, Kibana
  - Assistance with setup
  - General tips, e.g. for navigation and adding columns